

MOBİL UYGULAMA GÜVENLİĞİ VE VERİ TABANI YÖNETİMİ

1. SQL CRUD İŞLEMLERİ

PRAGMA foreign_keys=ON;

```
CREATE TABLE IF NOT EXISTS users(  
  id INTEGER PRIMARY KEY AUTOINCREMENT,  
  full_name TEXT NOT NULL,  
  email TEXT UNIQUE NOT NULL,  
  age INTEGER NOT NULL  
)
```

a. Tabloya kullanıcı ekleme:

```
INSERT INTO users(full_name,email,age) values('Betül Zağlı',betulzagli@gmail.com,21)  
INSERT INTO users(full_name,email,age) values('Ali Aksoy',aksoyali@gmail.com,34)  
INSERT INTO users(full_name,email,age) values('Ayça Akarsu',akarsuayca@gmail.com,29)  
INSERT INTO users(full_name,email,age) values('Vahide Sütçüoğlu',vahidestcoglu@gmail.com,21)
```

Sonuç:

id	full_name	email	age
1	Betül Zağlı	betulzagli@gmail.com	21
2	Ali Aksoy	aksoyali@gmail.com	34
3	Ayça Akarsu	akarsuayca@gmail.com	29
4	Vahide Sütçüoğlu	vahidestcoglu@gmail.com	21

b. Kullanıcıları Listeleme

SELECT * FROM users ; //Tüm kullanıcıları listeler

SELECT * FROM users WHERE age = 21; //Yaşı 21 olan kullanıcıları listeler

Sonuç: İlk satırdaki SQL sorgusunda karşımıza yine yukarıdaki tablo çıkacaktır çünkü tüm kullanıcılar listelenmiştir. Alt satırdaki sorgunun sonucu şu şekilde olacaktır:

id	full_name	email	age
1	Betül Zağlı	betulzagli@gmail.com	21
4	Vahide Sütçüoğlu	vahidestcoglu@gmail.com	21

c. Kullanıcılardan birinin email adresini güncelleme

UPDATE users SET email=vahideasker@gmail.com WHERE id=4;

Sonuç:

id	full_name	email	age
1	Betül Zağlı	betulzagli@gmail.com	21
2	Ali Aksoy	aksoyali@gmail.com	34
3	Ayça Akarsu	akarsuayca@gmail.com	29
4	Vahide Sütçüoğlu	vahideasker@gmail.com	21

d. Kullanıcılardan birini silme

DELETE FROM users WHERE id=2;

Sonuç:

id	full_name	email	age
1	Betül Zağlı	betulzagli@gmail.com	21
3	Ayça Akarsu	akarsuayca@gmail.com	29
4	Vahide Sütçüoğlu	vahideasker@gmail.com	21

2. INNER JOIN

Bu aşama için örnek bir users ve siparisler tablosu oluşturalım.

users:

id	full_name	email	location
1	Banu Alkan	aphrodit@gmail.com	Atina
2	Bülent Ersoy	divanız@gmail.com	İstanbul
3	Yıldız Tilbe	delikanlım@gmail.com	İzmir

order::

order_id	user_id	product	quantity
1	3	peruk	5
2	1	kürk	2
3	2	premium simli mikrofon	3

INNER JOIN NEDİR?

Inner join birden fazla tabloyu ortak bir sütun üzerinden birleştirmeye yarayan SQL sorgusudur. Bu sorgu tabloları eşleşen kayıtlar üzerinden birleştirir ve sadece eşleşen satırları sonuç olarak gösterir.

- Kullanıcının adını
- Email adresini
- Sipariş numarasını

aynı sonuç içerisinde listeleyen bir SQL sorgusunu yazacak olursak:

SELECT users.full_name, users.email, orders.order_id FROM users INNER JOIN orders ON [users.id](#) = orders.user_id;

Sorgunun çalışma şekli: SELECT ile kullanıcıları okuyup listemek istediğimizi söylüyoruz. Peşine yazdığımız parametreler yukarıda da belirttiğimiz ve sorgu sonucu elde etmek istediğimiz parametreleri gösteriyor. FROM diyerek join etmek istediğimiz ilk tablonun ismini girerek peşine INNER JOIN diyoruz ve iki tabloyu eşleşen kayıtlar üzerinden bağlamak istediğimizi söylüyoruz. ON ifadesi ise bu iki tabloyu hangi şart ile bağlayacağımızı gösteriyor. users tablosundaki kullanıcı id'leri ile orders tablosundaki kullanıcı id'lerinin aynı olduğu durumlarda çıktı vermesini söyleyerek iki tabloda da id'si bulunan kullanıcıların siparişlerini elde ediyoruz.

3. MOBİL UYGULAMA GÜVENLİĞİ

- A. Bir bankacılık uygulamasında kredi kartı bilgileri veya bakiye gösterilirken ekran görüntüsü alınmasını ve ekran kaydı yapılmasını engellemek neden önemlidir? Bankacılık ve kripto para uygulamaları gibi para akışının fazla olduğu ve kullanıcıların kritik bilgilerinin bulunduğu uygulamalarda ekran kaydını engellemek büyük önem taşır. Bu tarz uygulamalarda ekranın kötü amaçlı kişiler tarafından izlenmesi banka , şifre bilgileri gibi bilgilerin bu art niyetli insanların eline geçmesine sebep olacaktır.
- Android ve IOS için ekran güvenliğini sağlamak amacıyla aşağıdaki kodlar yazılabilir:
- Android →
- ```
window.setFlags(
 WindowManager.LayoutParams.FLAG_SECURE,
 WindowManager.LayoutParams.FLAG_SECURE
);
```
- Yukarıdaki kod bloğunda ekran izlenmesi engellenmektedir. FLAG\_SECURE bize “bu ekran içeriği ekran kaydı veya ekran görüntüsü gibi yöntemlerle saklanmasın.” diyor. Aynı satırı iki kere yazmamızın sebebi ise Windows’un bize koyduğu bir doğrulama kuralı.
- IOS→
- ```
import UIKit;
```
- // ekran blur ve karaltma işlemleri
- ```
private func checkScreenRecord(){
 if (UIScreen.main.isCaptured){
 print("Uyarı! Cihazda ekran kaydı açık.");
 }
}
```
- Bu kodda ise önce checkScreenRecord adında bir fonksiyon oluşturup UIScreen.main.isCaptured ile ekranın izlenip izlenmediğini kontrol ediyoruz ve eğer izleniyorsa ekrana uyarı veriyoruz.
- B. Bu tarz saldırılara gölgeleme saldırısı denir. Bu saldırı çeşidinde saldırgan yaptığı uygulamaya kullanıcıların ilgisini çekecek ve kullanmalarını sağlayacak bir arayüz tasarlar. Bu arayüz butonlar, login ekranları vb yapılar olabilir. Kullanıcı ilgisi doğrultusunda bu butonlara tıklama ve login ekranlarına bilgilerini girme eğilimindedir. Aslında olan şey ise bu arayüzlerin aslında başka bir uygulamanın butonunu veya login ekranının işlevini kopyalamasıdır. Yani burada saldırgan erişmek istediği uygulamanın bazı kısımlarını taklit ederek kendi uygulamasında gölgelediği arayüzler oluşturur. Bu şekilde kullanıcının bilgileri arkaplanda erişilmek istenen uygulamaya girilmekte ve veriler veya para çekilmektedir. Örneğin bir bankacılık uygulamasının giriş ekranı taklit edilerek kullanıcı bilgileri öğrenilebilir ve hesaptan para çekilebilir.

- C. Root veya jailbreak, bir cihazın işletim sisteminde üstün yetkilere sahip olmak ve normalde erişilemeyecek dosyalara erişebilmek anlamına gelir. Başk bir deyişle bu dosyalara normal kullanıcılar tarafından ulaşamazken cihazlarda yazılım kısıtları aşarak, yani root veya jailbreak yapılarak , ulaşılması demektir. Root veya jailbreak genellikle cihazı özelleştirme, yurtdışı cihazlarını kullanıma açma, resmi marketlerde bulunmayan uygulamaları indirmek amacıyla yapılır. Bu işlemde yazılımın bazı sınırları kaldırıldığı için cihaz dışarıdan gelen tehditlere karşı daha savunmasız olacaktır ve saldırganların sisteme sızması kolaylaşacaktır. Bu yüzden root/jailbreak yapmak güvenli değildir. Örneğin bir cihazda kurulu olan bankacılık uygulamasının normalde erişilemeyecek verileri root etme sebebi ile erişilebilir hale gelebilir ve saldırıya uğrayabilir.
- D. Kullanıcı bilgilerinin düz metin olarak bulunması bunların doğrudan okunabilir olduğu anlamına gelir. Veri tabanında bulunan böyle bir yapı olası bir saldırıda veri tabanındaki bilgilerin çalınması anlamına gelecektir. SQLCipher kullanıldığında ise bu veriler şifrelenmiş olur. Eğer bir kişi şifreleme anahtarlarına sahip değilse veri tabanındaki bilgilere erişemez, komut çalıştırmak isterse hata ile karşılaşır. Şifrelenmiş bir veri tabanında sorgu atabilmek için PRAGMA KEY, PRAGMA cipher\_page\_size gibi bazı anahtar bilgilerin verilmesi gerekir.
- E. Access token apilere çağrı yapmak için kullanılan bir anahtardır. Sunucuya bir istek atıldığında sunucu yanıt olarak bir access token üretir. Bu tokenin süresi 15 dakikadır ve yalnızca RAM’de tutulur. Refresh token ise access tokenin süresi dolduğunda yenisini almak için tutulan ve yaklaşık 30 gün ömrü olan bir tokendir. Refresh token güvenli depolama (keystore/keychain) içerisinde tutulur. Access tokenin kısa süreli olmasının sebebi, olası bir saldırıda zarar görme süresini minimuma indirmektir. Refresh tokenin süresi daha uzun olduğu için ve bu tokenle yeni bir access token alındığı için daha güvenli bir yerde tutulmalıdır. Çıkış veya çalınma durumlarında sunucu refresh tokeni iptal eder (revoke). Bu sayede saldırgan tokeni daha önceden ele geçirmişse bile daha fazla kullanamaz ve yeni access token üretemez.